

PASSWORD CRACKING TECHNIQUES AND COUNTERMEASURES

Password Cracking and Complexity

Password Cracking

It is the process of recovering passwords from the data transmitted by a computer system or from the data stored in it. The purpose of cracking a password might be to help a user recover a forgotten or lost password, as a preventive measure by system administrators to check for easily breakable passwords, or for use by an attacker to gain unauthorized system access.

Most attackers use password-cracking techniques to gain unauthorized access. An attacker may either crack a password manually by guessing it or use automated tools and techniques such as a dictionary or a brute-force method. Most password-cracking techniques are successful because of weak or easily guessable passwords.

Password Complexity

It plays a key role in improving security against attacks. It is the most important element that users should ensure while creating a password. The password should not be simple, as such passwords are prone to attacks. The passwords that you choose should always be complex, long, and difficult to remember. The password that you are setting for your account must meet the complexity requirements of the policy setting.

Password characters should be a combination of alphanumeric characters. Alphanumeric characters consist of letters, numbers, punctuation marks, and mathematical and other conventional symbols.

See the implementation that follows for the exact characters referred to here:

- Passwords that contain letters, special characters, and numbers: *ap1@52*
- Passwords that contain only numbers: *23698217*
- Passwords that contain only special characters: *&*#@!(%)*
- Passwords that contain letters and numbers: *meet123*
- Passwords that contain only letters: *POTHTMYDE*
- Passwords that contain only letters and special characters: *bob@&ba*
- Passwords that contain only special characters and numbers: *123@\$45*
- Passwords that contain only uppercase and lowercase letters, such as: *RuNnEr*
- Passwords that contain more than 20 characters comprising a phrase: such as *Hardto crackveryeasily*
- Passwords that contain shortcut codes or acronyms, such as *L8r_L8rNot2day* (i.e., later, later, not today)
- Passwords that contain frequently used words specifying websites, such as *ABT2_uz_AMZ!* (i.e., about to use Amazon!)
- Passwords that contain the first letters of words of a long sentence, such as *TffciwvMi16wiwdm5g* (i.e., the first foreign country I ever visited was Mexico in 2016 when I was doing my 5th grade)

Various Types of Password Attacks

Classification of password attacks depends on the attacker's actions, which are of the following four types:

- **Non-Electronic Attacks:** This is, for most cases, the attacker's first attempt at gaining target system passwords. Non-electronic or non-technical attacks do not require any technical knowledge about hacking or system exploitation. Techniques used to perform non-electronic attacks include shoulder surfing, social engineering, dumpster diving, etc.

- **Active Online Attacks:** This is one of the easiest ways to gain unauthorized administrator-level system access. Here, the attacker communicates with the target machine to gain password access. Techniques used to perform active online attacks include password guessing, dictionary and brute-forcing attacks, hash injection, LLMNR/NBT-NS poisoning, use of Trojans/spyware/keyloggers, internal monologue attacks, Markov-chain attacks, Kerberos password cracking, etc.
- **Passive Online Attacks:** A passive attack is a type of system attack that does not lead to any changes in the system. In this attack, the attacker does not have to communicate with the system, but passively monitors or records the data passing over the communication channel, to and from the system. The data are then used to break into the system. Techniques used to perform passive online attacks include wire sniffing, man-in-the-middle attacks, replay attacks, etc.
- **Offline Attacks:** Offline attacks refer to password attacks in which an attacker tries to recover cleartext passwords from a password hash dump. Offline attacks are often time-consuming but have a high success rate, as the password hashes can be reversed owing to their small keyspace and short length.
- **Dictionary :** In this type of attack, a dictionary file is loaded into a cracking application that runs against user accounts. This dictionary is a text file that contains several dictionary words commonly used as passwords. The program uses every word present in the dictionary to find the password. In addition to a standard dictionary, an attacker's dictionaries contain entries with numbers and symbols added to words (e.g., "3December!962"). Simple keyboard finger rolls ("qwer0987"), which many believe produce random and secure passwords, are thus included in such a dictionary. Dictionary attacks are more useful than brute-force attacks; however, the former cannot be performed in systems using passphrases.

Methods to improve the success of a dictionary attack:

- Use of several different dictionaries, such as technical and foreign dictionaries, which increases the number of possibilities
- Use of string manipulation along with the dictionary (e.g., if the dictionary contains the word "system," string manipulation creates anagrams like "metsys," among others)
- **Brute Force:** In a brute-force attack, attackers try every combination of characters until the password is broken. Cryptographic algorithms must be sufficiently hardened to prevent a brute-force attack, which is defined by the RSA as follows: "Exhaustive key-search, or brute-force search, is the basic technique for trying every possible key in turn until the correct key is identified."

A brute-force attack is when someone tries to produce every single encryption key for data to detect the needed information. Even today, only those with enough processing power could successfully perform this type of attack.

Cryptanalysis is a brute-force attack on encryption that employs a search of the keyspace. In other words, testing all possible keys is one of the attempts to recover the plaintext used to produce a particular ciphertext. The detection of a key or plaintext is better than a brute-force attack is one way of breaking the cipher. A cipher is secure if no method exists to break it other than a brute-force attack. In general, all ciphers are deficient in mathematical proof of security. If the user chooses keys randomly or searches randomly, the plaintext will become available on average after the system has tried half of all the possible keys.

- **Rule-based Attack:** Attackers use this type of attack when they obtain some information about the password. This is a more powerful attack than dictionary and brute-force attacks because the cracker knows the password type. For example, if the attacker knows that the password contains a two- or three-digit number, he/she can use some specific techniques to extract the password quickly.

By obtaining useful information, such as the method in which numbers and/or special characters have been used, and password length, attackers can minimize the time required to crack the password and therefore enhance the cracking tool. This technique involves brute force, a dictionary, and syllable attacks.

For online password-cracking attacks, an attacker will sometimes use a combination of both brute force and a dictionary. This combination falls into the categories of hybrid and syllable password-cracking attacks:

- **Hybrid Attack:** This type of attack depends on the dictionary attack. Often, people change their passwords merely by adding some numbers to their old passwords. In this case, the program would add some numbers and symbols to the words from the dictionary to try to crack the password. For example, if the old password is “system,” then there is a chance that the person will change it to “system1” or “system2.”
- **Syllable Attack:** Hackers use this cracking technique when passwords are not known words. Attackers use the dictionary and other methods to crack them, as well as all possible combinations of them.
- **Wire Sniffing: Packet sniffing** is a form of wire sniffing or wiretapping in which hackers sniff credentials during transit by capturing Internet packets. Attackers rarely use sniffers to perform this type of attack. With packet sniffing, an attacker can gain passwords to applications such as email, websites, SMB, FTP, rlogin sessions, or SQL. As sniffers run in the background, the victim remains unaware of the sniffing.

As sniffers gather packets at the data link layer, they can grab all the packets on the LAN of the machine running the sniffer program. This method is relatively hard to perpetrate and computationally complicated. This is because a network with a hub implements a broadcast medium that all systems share on the LAN. The LAN sends the data to all machines connected to it. If an attacker runs a sniffer on one system on the LAN, he/she can gather data sent to and from any other system on the LAN.

- **Password Guessing**
Password guessing is a password-cracking technique that involves attempting to log on to the target system with different passwords manually. Guessing is the key element of manual password cracking. The attacker creates a list of all possible passwords from the information collected through social engineering or any other method and tries them manually on the victim’s machine to crack the passwords.

The following are the steps involved in password guessing:

- Find a valid user
- Create a list of possible passwords
- Rank passwords from high to low probability
- Key in each password until the correct password is discovered

Hackers can crack passwords manually or by using automated tools, methods, and algorithms. They can also automate password cracking using a simple FOR loop or create a script file that tries each password in a list. These techniques are still considered manual cracking. The failure rate of this type of attack is high.

Password Cracking Tools

Password cracking tools allow the resetting of unknown or lost Windows local administrator, domain administrator, and other user account passwords. In the case of forgotten passwords, it even allows users instant access to their locked computer without reinstalling Windows. Attackers can use password-cracking tools to crack the passwords of the target system.

- **L0phtCrack**

Source: <https://www.l0phtcrack.com>

L0phtCrack is a tool designed to audit passwords and recover applications. It recovers lost Microsoft Windows passwords with the help of a dictionary, hybrid, rainbow table, and brute-force attacks, and it also checks the strength of the password.

Attackers use L0phtCrack to crack the password of the target to gain access to the system.

- **ophcrack**

Source: <https://ophcrack.sourceforge.io>

ophcrack is a Windows password-cracking tool that uses rainbow tables for cracking passwords. It comes with a graphical user interface (GUI) and runs on different OSs such as Windows, Linux/UNIX, etc.

Attackers use ophcrack to perform brute-force attacks and crack password hashes of the target system.

- **RainbowCrack**

Source: <http://project-rainbowcrack.com>

RainbowCrack cracks hashes with rainbow tables, using a time–memory trade-off algorithm. A traditional brute-force cracker cracks a hash in a manner that is different from that followed by a time-memory-tradeoff hash cracker. The brute-force hash cracker attempts all possible plaintexts one after the other during the cracking process. In contrast, RainbowCrack pre-computes all the possible plaintext hash pairs in the selected hash algorithm, charset, and plaintext length in advance and stores them in a “rainbow table” file. It may take a long time to pre-compute the tables, but once the pre-computation is finished, it is possible to easily and quickly crack the ciphertext in the rainbow tables.

Attackers use RainbowCrack to crack the password hashes of the target system.

Some password-cracking tools are listed as follows:

- **John the Ripper** (<https://www.openwall.com>)
- **hashcat** (<https://hashcat.net>)
- **THC-Hydra** (<https://github.com>)
- **Medusa** (<http://foofus.net>)

Password Attack Countermeasures

The best practices to protect against password cracking are listed as follows:

- Enable information security audit to monitor and track password attacks.
- Do not use the same password during the password change.
- Do not share passwords.
- Do not use passwords that can be found in a dictionary.
- Do not use cleartext protocols or protocols with weak encryption.
- Set the password change policy to 30 days.
- Avoid storing passwords in an unsecured location.
- Do not use any system's default passwords.
- Make passwords hard to guess by using 8–12 alphanumeric characters, with a combination of upper- and lower-case letters, numbers, and symbols. This is because strong passwords are hard to guess. Therefore, the more complex the password, the less vulnerable it is to attacks.
- Ensure that applications neither store passwords to memory nor write them to disk in cleartext. Passwords are always vulnerable to theft if they are stored in memory. Once the password is known, it is extremely easy for attackers to escalate their rights in the application.
- Use a random string (salt) as a password prefix or suffix before performing encryption. This nullifies pre-computation and memorization. Because the salt is usually different for each individual, it is impractical for attackers to construct tables with a single encrypted version of each candidate password. UNIX systems typically use a 12-bit set.
- Never use personal information (e.g., birth date, or a spouse's, child's, or pet's name) to create passwords. Otherwise, it becomes quite easy for those close to you to crack your passwords.
- Monitor the server's logs for brute-force attacks on user accounts. Although brute-force attacks are difficult to stop, they are easily detectable if the webserver log is monitored. For each unsuccessful login attempt, an HTTP 401 status code is recorded in the web server logs.
- Lock out those accounts that were subjected to too many incorrect password guesses. This provides protection against brute-force and guessing attacks.
- Perform a periodic audit of passwords in the organization.
- Check any suspicious application that stores passwords in memory or writes them to disk.
- Unpatched systems can reset passwords during buffer overflow or denial-of-service attacks. Make sure to update the system.
- Examine whether the account is in use, deleted, or disabled. Disable the user account if multiple failed login attempts are detected.
- Enable account lockout with a certain number of attempts, a counter time, and a lockout duration.

Reference:

EC-Council. (2021). *Ethical hacking essentials* (1st ed.). EC-Council.